COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.2 · Impersonation

Mestre CyberSec · **Lesson 2.2 — Impersonation** (5:52) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Roubo de identidade na conversa: BEC (Business Email Compromise — 'falo pelo CEO'); tailgating (entrar na porta atrás da pessoa); shoulder surfing (olhar sobre o ombro); dumpster diving (papel na lixeira); brand impersonation (falso suporte).

💡 Key Exam Highlights & Critical Concepts

- BEC: o email SE PASSA pelo executivo (vítima interna)
- Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC
- Tailgating: entra na porta atrás de quem tem acesso

🎯 Exam Tips & Typical CompTIA Scenarios

- 'sender claims to be an executive' = BEC
- 'follows an authorized person through a door' = tailgating/piggybacking

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.2 — Impersonation)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Business Email Compromise (BEC)

A social engineering attack where an attacker impersonates a trusted executive (usually CEO/CFO) via email to trick an internal employee into transferring funds or sharing sensitive data.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'sender claims to be an executive asking for a wire transfer' = BEC. Vítima é interna (funcionário), não o executivo.*

• Whaling

A highly targeted phishing attack specifically aimed at high-level executives (C-suite, board members) to steal credentials, authorize fraudulent transactions, or obtain strategic data.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'phishing targeting the CEO/CFO directly' = Whaling. NÃO confunda com BEC — em Whaling o executivo é a VÍTIMA, em BEC o executivo é o IMPOSTOR.*

• Tailgating

Physical social engineering where an unauthorized person follows an authorized individual through a controlled access point (door, gate) without presenting credentials.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'follows an authorized person through a door' = Tailgating. Sinônimo: piggybacking (mesma técnica na prova).*

• Piggybacking

Similar to tailgating, but the authorized person knowingly allows the unauthorized individual to pass through the access point (often out of politeness).

⚠️ ***Exam Trap:*** *Gatilho na prova: 'person holds the door open for someone behind them' = Piggybacking. Na prova, tailgating e piggybacking são usados como sinônimos.*

• Shoulder Surfing

Direct observation technique where an attacker watches a victim's screen, keyboard, or paperwork over their shoulder to capture passwords, PINs, or sensitive information.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'attacker looks over the victim's shoulder' ou 'watches someone enter a PIN' = Shoulder surfing. Mitigação: filtros de privacidade (privacy screens).*

• Dumpster Diving

Searching through trash, recycling, or discarded media to retrieve sensitive information such as printed documents, sticky notes, or unshredded reports.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'attacker searches through the company's trash' ou 'finds sensitive documents in a dumpster' = Dumpster diving. Mitigação: políticas de shredding e destruição de mídia.*

• Brand Impersonation

An attack where adversaries fake the identity of a well-known company (Microsoft, Apple, bank, tech support) via email, websites, or phone calls to steal credentials or deploy malware.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'fake Microsoft support calls user' ou 'email appearing to be from a known vendor' = Brand impersonation. Distinguir de BEC: aqui é empresa externa, não executivo interno.*

• Pretexting

Creating a fabricated scenario or false identity (the 'pretext') to manipulate a victim into revealing information or granting access, often impersonating IT, HR, or auditors.

⚠️ ***Exam Trap:*** *Gatilho na prova: 'attacker poses as IT support calling to reset password' = Pretexting. É a técnica-base por trás de muitas outras impersonations.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A finance analyst receives an email that appears to come from the CEO's name and photo. The message says the CEO is in a board meeting, cannot talk, and needs an urgent wire transfer to a new supplier before the end of the day. The reply-to domain resembles the company domain but uses a different top-level domain. Which type of impersonation attack is this most likely?

A) Business email compromise (BEC)

B) Whaling

C) Brand impersonation

D) Pretexting

QUESTION 2 · EXAM SCENARIO

A threat actor sends a carefully crafted email to the chief financial officer from a spoofed address pretending to be outside legal counsel. It references a confidential acquisition and asks the CFO to open an encrypted document and approve a payment before market open. Which impersonation category best describes the target and method?

A) Business email compromise (BEC)

B) Whaling

C) Tailgating

D) Shoulder surfing

QUESTION 3 · EXAM SCENARIO

An employee badges into a restricted research lab. Immediately behind them, a person carrying a cardboard box walks through the door before it closes, does not present a badge, and is not stopped. Which physical impersonation risk is demonstrated?

A) Shoulder surfing

B) Piggybacking

C) Tailgating

D) Dumpster diving

QUESTION 4 · EXAM SCENARIO

A server room door is opened by an employee leaving for lunch. A person in a technician uniform says they left their badge in the car and asks the employee to keep the door open. The employee complies, and the person enters the restricted area. Which physical access threat does this best illustrate?

A) Piggybacking

B) Tailgating

C) Shoulder surfing

D) Dumpster diving

QUESTION 5 · EXAM SCENARIO

While waiting at an airport gate, a remote worker logs into the corporate VPN on a laptop. A nearby traveler angles a phone toward the screen and records the username, password, and one-time code as they are typed. Which attack has occurred?

A) Tailgating

B) Shoulder surfing

C) Dumpster diving

D) Brand impersonation

QUESTION 6 · EXAM SCENARIO

An attacker collects discarded paper from the curb outside a company office. The documents include an internal phone list, a network diagram, and notes about a new cloud migration. The attacker later uses this information to call employees while pretending to be an IT engineer. Which impersonation-related technique was used to obtain the information?

A) Shoulder surfing

B) Pretexting

C) Dumpster diving

D) Whaling

QUESTION 7 · EXAM SCENARIO

Employees receive an email from 'Microsoft 365 Support' at support@microsoft-mailbox-verify.com. It uses Microsoft logos and warns that their mailbox will be disabled unless they sign in through a link. The link leads to a fake login page. Which impersonation tactic is being used?

A) Whaling

B) Tailgating

C) Brand impersonation

D) Dumpster diving

QUESTION 8 · EXAM SCENARIO

A help desk agent receives a phone call from someone claiming to be a new contractor. The caller provides a fake ticket number and says they are locked out of VPN access before a client demo. They ask the agent to reset the account and read the new password over the phone. Which social engineering technique is the caller using?

A) Shoulder surfing

B) Business email compromise

C) Pretexting

D) Dumpster diving

QUESTION 9 · EXAM SCENARIO

Accounts payable receives an email from a regular supplier's address. The message says the supplier changed banks and asks that all future invoices be paid to a new account. The email thread includes prior legitimate invoices, but the bank details are different. Investigation later shows the supplier's mailbox was compromised. Which type of impersonation attack best describes this?

A) Business email compromise (BEC)

B) Shoulder surfing

C) Tailgating

D) Brand impersonation

QUESTION 10 · EXAM SCENARIO

A company issues laptops to employees who frequently work in airports and cafes. The security team wants to reduce the risk of nearby people capturing passwords and sensitive data from laptop screens. Which control is most directly effective against this threat?

A) Privacy filter on the laptop screen

B) Access control vestibule at office entrance

C) Email gateway with DMARC enforcement

D) Cable lock anchored to a table

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Business email compromise (BEC)

Business email compromise (BEC) often uses a spoofed or look-alike executive address to pressure finance staff into urgent payments. Whaling targets executives themselves, brand impersonation abuses a company brand, and pretexting is the fabricated story used within BEC.

Question 2: Option B — Whaling

Whaling is spear phishing aimed at senior executives such as a CFO. The attacker impersonates outside counsel and uses a confidential acquisition to make the request credible. BEC usually involves impersonating an executive to target finance, while tailgating and shoulder surfing are physical or visual attacks.

Question 3: Option C — Tailgating

Tailgating occurs when an unauthorized person follows an authorized employee through a controlled door without the employee knowingly allowing it. Piggybacking would involve the employee intentionally holding or propping the door open for the unauthorized person.

Question 4: Option A — Piggybacking

Piggybacking occurs when an authorized employee knowingly allows an unauthorized person to enter a restricted area. The technician's excuse is pretexting, but the physical access threat is piggybacking. Tailgating would be entry without the employee's consent.

Question 5: Option B — Shoulder surfing

Shoulder surfing is direct visual observation or recording of sensitive information, such as credentials or MFA codes, from near the victim. A privacy screen or shielding the screen reduces the risk.

Question 6: Option C — Dumpster diving

Dumpster diving is obtaining information from discarded documents or media. The later phone call may involve pretexting, but the question asks how the information was obtained, which is dumpster diving.

Question 7: Option C — Brand impersonation

Brand impersonation mimics a trusted company or service, in this case Microsoft 365, to make a phishing page seem legitimate. Whaling targets executives; tailgating and dumpster diving are physical.

Question 8: Option C — Pretexting

Pretexting uses a fabricated identity and scenario, such as a new contractor with a fake ticket, to manipulate the help desk into resetting credentials. The attack is voice-based social engineering, not BEC or shoulder surfing.

Question 9: Option A — Business email compromise (BEC)

BEC includes vendor email compromise, where a trusted supplier's mailbox is compromised or spoofed to redirect payments. Brand impersonation would impersonate a brand such as Microsoft, not a known supplier thread.

Question 10: Option A — Privacy filter on the laptop screen

A privacy filter limits the viewing angle of a laptop screen, making it difficult for nearby people to capture passwords or data. An access control vestibule mitigates tailgating, DMARC mitigates email spoofing, and a cable lock mitigates theft.